

🔒 ТЕХНИЧЕСКИЙ ПАСПОРТ И СХЕМАТИЧЕСКИЙ РАЗБОР ГЛАВНОГО ДЕМОНА СЛУЖБЫ (main.py)

Настоящий документ содержит детальное архитектурное описание, профили безопасности и пошаговый структурный разбор всех ключевых эндпоинтов главного запускающего файла и координатора API-сервисов панели.

ГЛАВНЫЙ СЛУЖЕБНЫЙ ДЕМОН И ИНИЦИАТОР СЛУЖБЫ (main.py)

Контур обеспечивает запуск асинхронного жизненного цикла веб-панели (Lifespan), автоматическую проверку и инъект параметров суперпользователя и авторизацию операторов системы.

--- Схема асинхронного инициализатора Lifespan ---

СТАРТ СЛУЖБЫ SYSTEMD (Lifespan-Инициализатор)

↓ Сборка пула соединений (utils.init_pool())

ЭТАП А: ПРОВЕРКА ЦЕЛОСТНОСТИ ТАБЛИЦ ПАНЕЛИ

```
SELECT 1 FROM public.panel_users WHERE username = 'admin';
```

↓ Разветвление логики первого запуска системы

Пользователь 'admin' найден

Пропуск автоматической генерации мастер-аккаунта

База полностью пуста

INSERT 'admin' / Хэш 'admin123' (12 раундов
Bcrypt)

↓ Активация фонового контура очистки токенов

asyncio.create_task(users.token_garbage_collector()) → Сброс пула по сигналу остановки

🛡️ Профиль ИБ-защиты подсистем жизненного цикла и входа:

- **Защита от уязвимости отсутствия мастер-доступа:** Контекстный менеджер `lifespan` на старте FastAPI гарантирует, что система никогда не запустится в режиме «заблокированного входа». Если СУБД развернута с нуля, ядро автоматически инжектирует учетную запись `admin`. Её пароль записывается 12-раундным криптографическим Bcrypt-хэшем (`gensalt()`), предотвращая утечку исходного текста.
- **Противодействие тайминг-атакам (Time-Based Side-Channel Attacks):** Внутри эндпоинта `/api/login` проверка пароля методом `checkpw()` защищена от перебора по времени отклика. Если злоумышленник передает несуществующий логин, бэкэнд имитирует ложную валидацию хэша, выравнивая время ответа сервера и полностью лишая атакующего возможности удаленной разведки структуры базы данных.

- **Корректное удаление ресурсов операционной системы при шатдауне:** При получении системного сигнала об остановке или перезапуске процесса (`SIGTERM/systemctl stop`), секция завершения lifespan вызывает `.cancel()` для фонового демона токенов и каскадно уничтожает сокеты `utils.close_pool()`. Это исключает появление зависших зомби-поток в ОЗУ РЕД ОС / CentOS.

--- Подробное описание эндпоинтов веерного управления правами ---

- **Контур веерного наката и отзыва принудительных прав (POST /api/manage-privileges)** Маршрут осуществляет сквозное управление уровнями DATABASE, SCHEMA, TABLE, SEQUENCE. Внедрен функционал дефолтных прав: генерация и накат тяжелых команд ALTER DEFAULT PRIVILEGES происходит исключительно при массовом выделении (флаг ALL) или в режиме DEFAULT.

--- Схема веерного наката привилегий и ИБ-экранирования DDL ---

КОНТРОЛЛЕР ВЕЕРНОГО УПРАВЛЕНИЯ ПРИВИЛЕГИЯМИ СУБД

Входной параметр: `schema_param == "ALL"`

Входной параметр: конкретное имя (public)

Веерный перебор каталога

```
SELECT schema_name FROM
information_schema.schemata
```

Точечная фиксация

```
target_schemas = [s.strip() for s in split(', ')]
```

ИБ-Компиляция DDL: Безопасные токены `sql.Identifier(username)` и `sql.SQL(", ").join()` полностью исключают инъекции

Профиль ИБ-защиты эндпоинта управления привилегиями:

- **Защита от SQL-инъекций на динамическом DDL:** Поскольку команды управления правами (GRANT/REVOKE) и изменения дефолтных политик (ALTER DEFAULT PRIVILEGES) не поддерживают стандартные плейсхолдеры подготовленных запросов СУБД, в модуле реализована строгая компиляция через `psycopg.sql`. Имена объектов и ролей экранируются токеном `sql.Identifier`, а списки прав разделяются через безопасный джоин `sql.SQL(", ").join()`, на корню отсекая возможность внедрения кавычек и стороннего DDL-кода.
- **Изолированный механизм повторного исполнения транзакций (Retry):** При выполнении массовых операций СУБД может вернуть ошибку конкурентной блокировки кортежей или взаимного исключения каталогов. Модуль перехватывает ошибки со словами "lock", "deadlock" или "concurrent" и осуществляет повторную попытку наката через фиксированную ИБ-паузу `time.sleep(0.1)`, минимизируя сбой рантайма.
- **Предотвращение размазывания дефолтных прав схемы:** Функционал на строках 803–804 жестко контролирует вызовы `ALTER DEFAULT PRIVILEGES`. Если оператор выдает точечные права на одну конкретную таблицу, глобальные настройки создания будущих объектов схемы не затрагиваются, предотвращая несанкционированное наследование привилегий новыми сущностями.

--- Подробное описание эндпоинтов сетевого мониторинга и аудита сессий ---

- Подсистема динамических селекторов (GET /api/get-target-*) Инфраструктурные роуты выгрузки баз данных, схем, таблиц и ролей защищены сквозным перехватчиком сетевых таймаутов. В словари конфигураций принудительно внедряется параметр "connect_timeout": 5. Любые обрывы связи или молчание удаленного хоста PostgreSQL изолируются в блоки try-except, маскируя сырой traceback СУБД в чистые JSON-ответы с кодом 500 для предотвращения разведки топологии сети.
- ИБ-Эндпоинт контроля и расследования инцидентов сессий (GET /api/auth/verify-role) Используется фронтендом для рантайм-контроля валидности JWT-токенов операторов. Внутренняя логика жестко разделяет штатное протухание сессии и целенаправленную атаку деформации пакетов. Истекший токен логируется с мягким уровнем INFO. Попытки подделки подписи или инъектов перехватываются, маркируются уровнем CRITICAL под тегом [ИБ-АУДИТ] !!! КРИТИЧЕСКАЯ КОМПРОМЕТАЦИЯ СЕССИИ, извлекают IP-адрес атакующего через прокси-заголовки Nginx (x-real-ip) и сбрасывают сокет.

--- Схема изоляции сетевой разведки инстансов СУБД ---

КОНТУР СЕТЕВОЙ РАЗВЕДКИ (POST /api/test-server-connection)

↓ Presetting: db_config["connect_timeout"] = 5

ПОПЫТКА УСТАНОВЛЕНИЯ ПРЯМОГО TCP-СОЕДИНЕНИЯ С ХОСТОМ

Исполнение легковесного strict-запроса: SELECT 1;

↓ Каскадный перехват сетевых крахов

Узел доступен и ответил за 5с

utils.log_operation(status="success")

Ответ: HTTP 200 Подключение установлено!

Узел мертв / Заблокирован Firewall

logger.error([ИБ-АУДИТ] !!! СБОЙ

ПОДКЛЮЧЕНИЯ)

Изоляция в HTTP 400 (Без вывода паролей и стека)

ФИНАЛ: ВЫСВОБОЖДЕНИЕ ДЕСКРИПТОРОВ СОКЕТОВ ИЗ RAM ПАМЯТИ